
Law & Data

Summary Notes

Department of Mathematics — School of Science

Based on material from A.Y. 2024–2025

Concept-dense summary of the course. Legal instruments (treaties, conventions, regulations, directives, articles, cases) are catalogued with loci and dates in the companion file `laws.pdf`; here they are used and explained. The summary is built so every closed and open exam question can be answered from it.

Contents

1	Foundations of Law	3
1.1	Law, Legal Order, Legal System	3
1.2	Separation of Powers & General Principles	3
1.3	Branches of Law	3
1.4	Civil Law vs Common Law	3
2	Sources of Law & Hierarchy	4
2.1	Hard Law vs Soft Law	4
2.2	Categories of Sources	4
2.3	Hierarchy of Sources	4
3	The European Union	5
3.1	Origins & Nature	5
3.2	Membership (Accession)	5
3.3	Rule of Law	5
3.4	Related European Organisations (distinct from the EU)	5
4	EU Institutions	6
4.1	Court of Justice of the EU (CJEU)	6
4.2	Data-Protection Bodies	6
5	EU Law: Primary, Secondary, Supplementary	7
5.1	Primary Law	7
5.2	International Agreements	7
5.3	Secondary Law (Art. 288 TFEU)	7
5.3.1	The Shift from Directives to Regulations in Data Protection	8
5.3.2	Examples of EU Secondary Legislation on Data	8
5.4	Supplementary Law	8
6	Privacy: Concept & Evolution	9
6.1	The Concept of Privacy	9
6.2	Historical Development	9
6.3	Common Law vs Civil Law Paradigms; EU vs US	9
6.4	Privacy vs Personal Data Protection	9
7	From Privacy to Data Protection: Instruments	10
7.1	Personal Data Protection in EU Primary Law (open-question)	10
8	General Data Protection Regulation (GDPR)	11
8.1	Scope	11
8.2	Key Definitions (Art. 4)	11
8.3	Principles of Processing (Art. 5)	11
8.4	Lawful Bases (Art. 6)	12
8.5	Data Protection by Design & by Default (Art. 25)	12
8.6	DPMS vs DPIA	12
8.7	Main Subjects (open-question)	12
9	E-Privacy, Electronic Communications & Law Enforcement	14
9.1	ePrivacy Directive (2002/58/EC)	14
9.2	European Electronic Communications Code (Dir. (EU) 2018/1972, “Recast”)	14
9.3	Law Enforcement Directive (Dir. (EU) 2016/680)	14

10 European Data Strategy (2020)	15
10.1 Three Aims	15
10.2 EU 2016 Data Protection Package (open-question)	15
10.3 Legislative Package (open-question)	15
11 The Artificial Intelligence Act (Regulation 2024/1689)	16
11.1 Rationale	16
11.2 Subject Matter and Scope (Art. 1–2)	16
11.3 Key Definitions (Art. 3)	16
11.4 Risk-Based Framework	17
11.5 Prohibited Practices (Art. 5)	17
11.6 High-Risk Classification (Art. 6, Chapter III)	17
11.7 Requirements for High-Risk Systems (Art. 9–15)	18
11.8 Challenges and Fundamental Rights	18
11.9 Entry into Force and Timeline	18
12 Key Cases & Cross-Cutting Concepts	19
12.1 Leading Cases	19
12.1.1 Van Gend en Loos (26/62, 1963)	19
12.1.2 Costa v. ENEL (6/64, 1964)	19
12.1.3 Schrems v. Facebook (2015)	19
12.1.4 Google Spain — Costeja Gonzalez (C-131/12, 2014)	19
12.1.5 Digital Rights Ireland (C-293/12 + C-594/12)	20
12.2 Proportionality Scrutiny (open-question)	20
12.3 Social Credit Systems (open-question)	20
12.4 Barbra Streisand Effect (open-question)	20
12.5 Synthetic Data (open-question)	20
12.6 Big Data	21
13 Privacy Policy Components	22
A Quick Reference Tables	23
A.1 Data Subject Rights under GDPR	23
A.2 Controller vs Processor Obligations	23
A.3 GDPR Principles Summary	23
A.4 Sources Hierarchy (EU)	23
B EU Institutional Infrastructure	24
B.1 Core Institutions (Art. 13 TEU)	24
B.2 Council of the EU vs European Council (don't confuse)	24
B.3 CJEU — Two Courts	25
B.4 Data-Protection Bodies	25

1 Foundations of Law

1.1 Law, Legal Order, Legal System

Purpose of law

Law solves and prevents conflicts and safeguards freedom: my freedom ends where another's begins, so everyone has equal possibilities and choices.

- **Legal Order** (H. Kelsen) — a collection of general and specific norms regulating human behaviour; a set of norms forms an **order** when they share the **same basis of validity** (a unified system). In positive law, norms are “posited” by human **legal acts** (binding customs, judicial decisions, administrative acts, contracts) performed by **legal officials**.
- **Legal System** — the order plus three elements: **rules, procedures, institutions** by which public/private activity is carried out through legitimate means. There is a **plurality** of legal systems (states, EU, international order, arguably the Web).

A legal system need **not** coincide with a country (e.g. the EU spans 27 member states).

1.2 Separation of Powers & General Principles

Separation of powers (Montesquieu)

Powers must be held by **different institutions** so each checks the others (checks & balances), preventing concentration of power in a single entity.

- **Legislative** — makes law (parliaments, also governments).
- **Executive** — implements/enforces law (public administration).
- **Judicial** — interprets and enforces law when conflicts arise.

Fundamental principles a legal system must ensure:

- **Legal certainty** — know in advance what is permitted/forbidden and the sanctions.
- **Impartiality** — right to a fair trial (natural or legal persons).
- **Equality before the law** — everyone treated equally, regardless of nature (individuals or legal persons).

1.3 Branches of Law

- **Public law** — deals with the **public interest**; governs relations citizen-state (administrative, constitutional, criminal law).
- **Private law** — governs relations between private persons/entities (contract, family law).

The divide is **universal and exhaustive**: every sub-branch belongs to one or the other. Data protection sits mainly in **public law** (a fundamental right) but touches private law (we “give” our personal data).

1.4 Civil Law vs Common Law

Civil Law	Common Law
Mostly written laws (codes, statutes); hierarchy from constitutions/treaties down to regulations.	Mostly judicial decisions / precedent; judges interpret and set guidelines binding future similar cases.

2 Sources of Law & Hierarchy

2.1 Hard Law vs Soft Law

- **Hard law** — binding provisions enforceable before a court (statutes, regulations, treaties; UN Security Council resolutions, customary international law). Mandatory; breach → sanctions.
- **Soft law** — agreements, principles, declarations, recommendations, guidelines, codes of conduct; **not legally binding** but morally/politically binding, and they guide interpretation and the development of hard law.

Classic soft-law example: the **UN Declaration of Human Rights (1948)** — adopted by the UN General Assembly, no binding force. By contrast the **EU** and **Council of Europe** expressly provide sanctions for states. (See `laws.pdf` §1–2.)

2.2 Categories of Sources

- **International treaties & conventions**
- **Legislation** — constitutions, acts, laws, statutes, regulations, codes
- **Case law** — judicial decisions
- **Public/private policies** — e.g. consent on data processing
- **Doctrine** — scholarly writing
- **General principles of law**
- **Customary law** — long-standing practice (*diuturnus*) recognised as binding (*opinio iuris ac necessitatis*); e.g. customs recognised by the Court of Justice in the 1960s gave birth to the EU Charter of Fundamental Rights

2.3 Hierarchy of Sources

Reversed pyramid

Higher sources cannot be contradicted by lower ones (with limited exceptions). A constitution safeguarding free expression cannot be limited by a mere administrative regulation. EU order: **primary law** > **international agreements** > **secondary law** > **supplementary law** (case law + general principles).

For a detailed breakdown of each tier in the EU legal order see Section 5.

3 The European Union

3.1 Origins & Nature

- Born to **avoid conflicts** (two world wars in 30 years) and for economic integration. **Six founders** (1952): Italy, Netherlands, Belgium, Luxembourg, France, Germany.
- A **new legal order**: states **limited their sovereignty** for collective benefit (cf. *Costa v. ENEL*; *Van Gend en Loos*, [laws.pdf](#) §6). **27 member states** (28 until the UK left in 2020). EU law is integrated into national law, ensuring uniformity.
- Evolved through treaties since 1952 (Rome, Maastricht, ...). Until 2009 the EU was legally three pillars: European Community; justice & internal affairs; common security & defence. From Maastricht (1992) it is a **union**, not a community. (Treaty timeline: [laws.pdf](#) §3.)

3.2 Membership (Accession)

- **Art. 2 TEU** values are the precondition; **Art. 49 TEU** sets the procedure (application to Council, then Commission & Parliament; majority vote; treaties amended to admit the new state; national ratification).
- **Copenhagen Criteria** (3 groups of requirements):
 - **Political** — stable democratic institutions, rule of law, human rights, protection of minorities.
 - **Economic** — functioning market economy able to cope with competition/market forces.
 - **Administrative/institutional** — capacity to implement the **acquis communautaire** (the accumulated body of EU law, in being since 1993) → **legislative harmonisation**.
- **Candidates**: Ukraine (since 2022), Albania, Bosnia-Herzegovina, Georgia, Moldova, Montenegro, North Macedonia, Serbia, Turkey. Potential: Kosovo.

3.3 Rule of Law

All public powers must act within the constraints set by law. Requires: transparent, accountable, democratic, pluralistic law-making; effective & independent judicial protection; equal protection; protection of political/civil rights. Crucial to the functioning of the EU legal system.

3.4 Related European Organisations (distinct from the EU)

Organisation	Notes
Council of Europe (CoE)	46 member states; upholds human rights, democracy, rule of law. Runs the ECHR and the European Court of Human Rights (Strasbourg). Relevant to the right to privacy .
EFTA	Est. 1960 (EFTA Convention); free trade. Members: Iceland, Norway, Liechtenstein, Switzerland. Linked to the Schengen Agreement (1985) abolishing border checks.
EEA	Agreement from 1994; EU + EFTA (excl. Switzerland). Extends the Single Market (four freedoms: goods, services, capital, people) — GDPR matters here too.

“Fifth freedom” (scholarly): free movement of **personal data**.

4 EU Institutions

Established by **Art. 13 TEU**.

Institution	Role
European Parliament	720 members, directly elected (since 1979) for 5 years; co-legislator + budgetary + supervisory powers; elects the Commission President. Seats: Strasbourg, Brussels, Luxembourg.
European Council	Heads of state/government (27); sets overall political direction; does not legislate .
Council of the EU	One minister per member state; first legislative chamber; co-legislates with Parliament; amends/approves/vetoes Commission proposals.
European Commission	27 commissioners; sole initiator of legislation; enforces EU law; executive & budgetary powers; represents the EU externally (signs international agreements).
Court of Justice of the EU (CJEU)	Ensures uniform interpretation/application of EU law.
European Central Bank (ECB)	Manages the euro and monetary policy.
Court of Auditors	Oversees EU finances.

4.1 Court of Justice of the EU (CJEU)

Two courts: **Court of Justice** (preliminary rulings, annulments, appeals; one judge per state + 11 advocates general) and **General Court** (annulment actions by individuals/companies/governments — competition, State aid, trademarks; two judges per state). Judges are **not elected** (independent, appointed 6-year renewable terms). Functions: jurisdictional, interpretative (preliminary rulings), advisory.

- **Litigation proceedings (TFEU)**: direct appeals/annulment (Art. 263; 2 months + 10 days); failure to act (Art. 265); damages (Art. 340(2)). Also infringement proceedings against states.
- **Non-litigation: preliminary rulings (Art. 267)** — national judge refers; the CJEU rules *how* to interpret EU law, the national judge then decides; binding on that judge but the CJEU cannot interpret national law.

4.2 Data-Protection Bodies

- **EDPS** (European Data Protection Supervisor) — independent body supervising processing carried out by **EU institutions only**; handles their data-breach reports.
- **EDPB** (European Data Protection Board) — **independent body gathering the national supervisory authorities** of each member state; ensures consistent application of data-protection rules (successor to the Art. 29 Working Party).
- Also: agencies of the Commission; **Fundamental Rights Agency** (Vienna).

5 EU Law: Primary, Secondary, Supplementary

5.1 Primary Law

Primary law comprises four categories of **treaties**, the **Charter of Fundamental Rights**, and **general principles** established by the Court of Justice. Treaties include: **founding treaties** (establishing EC → EU); **amending treaties**; **protocols annexed to treaties**; and **accession treaties**. The EU currently rests on two operative treaties: the **TEU** (values: Art. 2; objectives: Art. 3; institutions: Art. 13) and the **TFEU** (organisational and functional provisions; Art. 16(1): “*Everyone has the right to the protection of personal data concerning them*”). Full article catalogue in `laws.pdf` §3.

- **Charter of Fundamental Rights** — proclaimed 2000 (Nice), **binding since 2009** (Lisbon Treaty; **Art. 6(1) TEU**: the Charter “shall have the same legal value as the Treaties”). Seven chapters: **I Dignity** (“Human dignity is inviolable, it must be respected and protected”), **II Freedoms** (incl. **Art. 7** private/family life; **Art. 8** personal data), **III Equality**, **IV Solidarity**, **V Citizens’ Rights**, **VI Justice**, **VII General Provisions** (safeguard clause **Art. 52**: limitations must be provided by law, respect the essence of the right, be necessary and proportionate).
- **General principles of EU law** — developed by the Court of Justice over time; **no exhaustive list**, under constant development, stemming from constitutional traditions of member states. **Art. 6(3) TEU**: “Fundamental rights, as guaranteed by the European Convention for the Protection of Human Rights and Fundamental Freedoms and as they result from the constitutional traditions common to the Member States, shall constitute general principles of the Union’s law.” Examples: legal certainty, legitimate expectation, **primacy** and **direct effect** of EU law, proportionality, protection of fundamental rights.

5.2 International Agreements

Concluded by the EU with third countries/organisations (**Art. 216–218 TFEU**); once concluded, directly applicable and binding on all member states (part of the *acquis*). E.g. the EU-US agreement on transfer of personal data.

- **Art. 216 TFEU** — the Union *may* conclude an agreement where the Treaties so provide, where conclusion is necessary to achieve a Treaty objective, where provided for in a binding Union act, or where likely to affect common rules or alter their scope. Agreements concluded are binding on the institutions and on member states.
- **Art. 217 TFEU** — the Union may conclude **association agreements** with third countries or international organisations, establishing an association involving **reciprocal rights and obligations**, common action and special procedure.
- **Art. 218 TFEU** — procedure for negotiating and concluding international agreements, involving the Council, the European Parliament (and possibly the CJEU for an opinion on compatibility).

5.3 Secondary Law (Art. 288 TFEU)

Regulations vs Directives (exam staple)

Regulations — binding in entirety, **directly applicable** in all member states, **no** transposition (uniform, immediately enforceable). **Directives** — bind as to the **result**, leaving form/method to states (**require transposition**); after the deadline, clear/precise/unconditional provisions have **direct effect**.

- **Decisions** — binding **in their entirety**; may be **general** (addressed to all member states

or entities) or **individual** (addressed to specific persons or states); a decision that specifies those to whom it is addressed is binding **only on the addressees**.

- **Recommendations & opinions** — soft law, not binding.
- **Atypical acts** — communications, resolutions, white/green papers.

5.3.1 The Shift from Directives to Regulations in Data Protection

Early EU data protection relied on **directives**: Directive 95/46/EC (general framework) and Directive 2002/58/EC (electronic communications) required national transposition, leaving each member state to choose the form and method of implementation. Under this **liability-based approach**, entities were bound only by national implementing law (not by EU law directly), and enforcement was reactive — states faced infringement proceedings for non-transposition; entities faced sanctions only after violations occurred. Different national implementations produced **fragmentation** and legal uncertainty across the single market.

The shift to **regulations** — the GDPR (2016/679) and Regulation 2018/1725 (EU institutions) — introduced a **compliance-oriented approach**: regulations are directly applicable without transposition, so entities are bound by EU law directly. Crucially, the GDPR's **accountability principle** (Art. 5(2)) requires controllers to **proactively demonstrate** compliance rather than merely avoid liability after the fact. This is operationalised through data protection by design/default (Art. 25), the mandatory DPIA before high-risk processing (Art. 35), records of processing activities (Art. 30), and the DPO as an internal compliance officer. The result is **maximum harmonisation** and uniform rules throughout the EU. Directive 2016/680 (law enforcement sector) retains directive form where per-state flexibility is considered necessary.

5.3.2 Examples of EU Secondary Legislation on Data

The following instruments illustrate how secondary law on data has developed, mixing directives and regulations according to the degree of uniformity sought:

- **Directive 95/46/EC** — Data Protection Directive; the first general EU framework; replaced by the GDPR.
- **Regulation (EU) 2016/679** (GDPR) — general personal data protection framework; directly applicable from 25 May 2018.
- **Directive (EU) 2016/680** — Law Enforcement Directive; data protection in police/criminal justice; requires transposition.
- **Regulation (EU) 2018/1725** — data protection for processing by EU institutions, bodies, offices, and agencies.
- **Directive 2002/58/EC** — ePrivacy Directive; personal data and privacy in electronic communications; requires transposition.
- **Regulation (EU) 2024/1689** — AI Act; harmonised rules on artificial intelligence systems that process data.

5.4 Supplementary Law

Lowest level: **case law** of the CJEU and **general principles**; crucial for interpreting and filling gaps in primary/secondary law.

6 Privacy: Concept & Evolution

6.1 The Concept of Privacy

- Dimensions: reputation, honour, private & family life, control over personal information; underpins the private/public distinction.
- **Negative connotation** — preventing **intrusions** from the external space (the older, liberty-based view).
- **Positive connotation** — **self-determination**: the right to make free choices and to choose whom to exclude from one's private space (the evolved, EU view).

6.2 Historical Development

- Early regulation: 14th-c. England; **Justice of the Peace Act** (UK) — among the first acts giving remedies against eavesdroppers. 19th-c. France/Norway: sanctions for publishing private information.
- **Warren & Brandeis, “The Right to be Let Alone” (1890)** — privacy as a human right (reputation, honour, image, family life); emphasises autonomy and the control of personal information; marks public vs private.

6.3 Common Law vs Civil Law Paradigms; EU vs US

EU (civil-law, dignity)	US (common-law, liberty)
Privacy/data protection as fundamental rights of the individual; dignity-based.	Privacy as liberty (freedom from intrusion); protects the consumer/market .
Opt-in : explicit consent required before processing; data minimisation/necessity.	Opt-out : collection presumed; user must object. Sharing encouraged for economic gain.

6.4 Privacy vs Personal Data Protection

- Related but **distinct** rights: privacy is a **general** right (anti-interference, **Art. 7 CFR**); personal data protection refers only to **information** and its processing conditions (**Art. 8 CFR**).
- Data protection recognised as an **autonomous** fundamental right only in the EU, only since the Charter entered into force (2009).

Some scholars foresee a “fourth generation” of human rights for the online environment.

7 From Privacy to Data Protection: Instruments

Chronology of the instruments that built personal data protection (loci/dates in `laws.pdf` §1–3):

Instrument	Date	Contribution
UDHR Art. 12 (UN)	1948	First recognition of privacy; soft law , negative connotation.
ECHR Art. 8 (CoE)	1950	Right to respect for private/family life; interference only if lawful & necessary in a democratic society.
ICCPR	1966	First hard-law recognition of privacy.
OECD Privacy Guidelines	1980	First international instrument with principles for data processing (8 principles); soft law.
Convention 108 (CoE)	1981	First binding international instrument on data protection; basis of accountability .
UN Convention Rights of the Child, Art. 16	1989	Children's privacy; dignity-based.
Directive 95/46/EC	1995	EU Data Protection Directive (later replaced by GDPR).
Charter Art. 7 & 8 (Nice, soft)	2000	Privacy + autonomous data-protection right.
Convention 108+	2018	Modernisation aligned with the GDPR.
Charter becomes binding (Lisbon)	2009	Art. 7/8 become hard law ; Art. 16 TFEU.

7.1 Personal Data Protection in EU Primary Law (open-question)

- **Art. 2 & 3 TEU** — fundamental rights as **values** and **objectives** of the Union (incl. human dignity, Art. 1 CFR).
- **Art. 16 TFEU** — explicit right to protection of personal data; legal basis for EU legislation (Parliament + Council). **Art. 39 TEU** — data protection in CFSP, adopted by the **Council alone**; *lex specialis* over Art. 16.
- **Art. 8 CFR** — autonomous fundamental right (fair processing, specified purposes, consent/legitimate basis, access & rectification, independent supervision). **Art. 7 CFR** — private/family life: Art. 7 protects *against interference*, Art. 8 governs the *rules* of processing.
- **Art. 52 CFR** — limitations must be provided by law, respect the essence of the right, be necessary & proportionate (balancing of conflicting rights).

8 General Data Protection Regulation (GDPR)

Regulation (EU) 2016/679, applicable **25 May 2018**; replaced Directive 95/46/EC. Sets a comprehensive framework for processing personal data, in and outside the EU. Article catalogue: [laws.pdf §5](#).

8.1 Scope

- **Material** — automated processing + structured filing systems; **exceptions**: household/personal activity, areas outside EU competence, law enforcement (governed by Dir. 2016/680).
- **Territorial** — **extraterritorial**: applies to non-EU entities offering goods/services to, or monitoring the behaviour of, persons in the Union (the **Brussels Effect**: EU rules become de facto global standards).

8.2 Key Definitions (Art. 4)

- **Personal data (Art. 4(1))** — any information relating to an **identified or identifiable** natural person (the **data subject**), directly or indirectly (name, ID number, location, online identifier, or physical/physiological/genetic/mental/economic/cultural/social factors).
- **Sensitive data / special categories (Art. 9)** — data revealing racial/ethnic origin, political opinions, religious/philosophical beliefs, trade-union membership; genetic data; biometric data processed for the purpose of uniquely identifying a natural person; health data; data concerning sex life or sexual orientation. Processing is **prohibited in principle**; permitted only under ten exceptions: explicit consent (for specified purposes); employment/social security/social protection law; vital interests; legitimate activities of foundations, associations or non-profit bodies for their members or former members; data **manifestly made public by the data subject**; legal claims; substantial public interest; **preventive or occupational medicine**; health in the public interest; scientific or historical research in the public interest.
- **Processing** — any operation or set of operations performed on personal data or on sets of personal data, whether or not by automated means: collection, recording, **organisation, structuring**, storage, adaptation or alteration, retrieval, consultation, use, disclosure by transmission, dissemination or otherwise making available, **alignment or combination**, restriction, erasure or destruction.
- **Purposes** — not expressly defined by the GDPR; understood as the **aims** for which personal data are collected and processed. Must be specified, explicit and legitimate at the time of collection (purpose limitation principle).
- **Consent** — freely given, specific, informed, unambiguous indication, by statement or clear affirmative action.

8.3 Principles of Processing (Art. 5)

1. **Lawfulness, fairness, transparency** — valid legal basis (Art. 6), fair processing, transparent disclosure to the data subject: identity of controller, purposes of processing, data subject rights, confirmation and communication of processing activities, risks/rules/safeguards applicable.
2. **Purpose limitation** — purposes must be specified, explicit and legitimate at collection; further processing only if compatible. Two sub-requirements: **legitimacy** (accordance with existing applicable law) and **detail of purpose** (further operations must be verified as compatible with initial purposes).
3. **Data minimisation** — adequate, relevant and **limited** to what is necessary for the purposes; requires a proportionality assessment and appropriate technical and organisational measures.

4. **Accuracy** — personal data must be accurate, kept up to date, and **reflect the reality of any given situation**; if inaccurate, must be erased or rectified; inaccuracy may imply legal consequences for the subjects involved.
5. **Storage limitation** — kept in a form that permits identification of data subjects **for no longer than necessary** for the processing purposes (strict minimum); Art. 17 erasure obligation.
6. **Integrity & confidentiality** — appropriate security (encryption, pseudonymisation); stronger for high-risk data.
7. **Accountability** — controllers must **demonstrate** compliance (origin: Convention 108).

8.4 Lawful Bases (Art. 6)

Consent; **contract** (or pre-contract steps); **legal obligation** (e.g. tax reporting); **vital interests**; **public-interest task** (e.g. a university issuing certificates); **legitimate interests** of the controller/third party (not overriding the subject's rights).

8.5 Data Protection by Design & by Default (Art. 25)

- **By design** (proactive) — the controller must, **both at the time of determination of the means for processing and at the time of processing itself**, implement appropriate TOMs (e.g. pseudonymisation) designed to implement data-protection principles such as data minimisation and to integrate the necessary safeguards, in order to meet the GDPR's requirements and protect data subjects' rights.
- **By default** — the controller must implement appropriate TOMs to ensure that, by default, **only personal data which are necessary for each specific purpose** are processed. This obligation applies to the **amount** of data collected, the **extent** of their processing, the **period of storage** and their **accessibility**; by default, personal data must not be made accessible without the individual's intervention to an **indefinite number of natural persons**.

8.6 DPMS vs DPIA

- **DPMS** (Data Protection Management System) — ongoing IT/organisational tool to choose and document the appropriate TOMs for compliance.
- **DPIA** (Data Protection Impact Assessment) — assessment of the impact of envisaged processing operations on the protection of personal data; carried out by the **controller** in consultation with the **DPO**. **Mandatory** in three cases: (1) systematic/extensive evaluation of personal data based on automated processing, including profiling; (2) large-scale processing of **special categories** of data; (3) systematic monitoring of a **publicly accessible area** on a large scale. Contents: (a) systematic description of envisaged processing operations, purposes, and legitimate interest of the controller (if any); (b) assessment of **necessity and proportionality** in relation to the purposes; (c) assessment of **risks** to rights and freedoms of data subjects; (d) measures envisaged to address the risks, including safeguards, security measures and mechanisms to demonstrate compliance. Embodies the GDPR's **risk-based** approach.

8.7 Main Subjects (open-question)

- **Data subject** — the identified/identifiable individual; holds enforceable rights (below).
- **Controller** — determines **purposes and means**; primary accountability. (Two+ jointly → **joint controllers**, same liability.) Duties: adopt TOMs, keep records, cooperate with subjects/authorities.
- **Processor** — processes **on behalf** of the controller, on its instructions (Art. 28 contract). Main obligations: act upon controller's instructions; implement TOMs; appoint a represen-

tative within the EU; **maintain a record of processing activities**; cooperate with supervisory authorities; designate a DPO (where required); may delegate to a **sub-processor**.

- **DPO** (Data Protection Officer) — advises on/monitors compliance; bridge to authorities. **Voluntarily appointed** by controllers/processors, unless mandatory: (a) processing by a public authority or body; (b) core activities require **regular and systematic monitoring of data subjects on a large scale**; (c) core activities consist of large-scale processing of **special categories** or criminal-conviction data.
- **Record of processing activities** — both controllers and processors must maintain a record. **Controller record** contains: name and contact details of (joint) controllers, representatives and DPOs; purposes; categories of data subjects and personal data; categories of recipients (including outside EU/international organisations); transfers to third countries and safeguards; envisaged time-limits for erasure; general description of TOMs. **Processor record** contains: name and contact details of processor(s), (joint) controllers, representatives and DPOs; categories of processing; transfers to third countries and safeguards; general description of TOMs.
- **Supervisory authority** — independent public authority established by each member state pursuant to **Art. 51 GDPR** (primary-law basis: Art. 8 CFR). Dual mandate: (a) protect fundamental rights and freedoms of natural persons in relation to processing and **facilitate the free flow of personal data** within the Union; (b) contribute to the **consistent application** of the GDPR throughout the Union and collaborate with the European Commission. Tasks: handle data subjects' complaints; monitor GDPR application; ensure consistency via the EDPB.

9 E-Privacy, Electronic Communications & Law Enforcement

9.1 ePrivacy Directive (2002/58/EC)

Regulates personal data **and data in general** in the **electronic communications** sector; still in force; **needs transposition** per member state. Covers confidentiality of communications, **cookies**, unsolicited marketing, breach notification.

- Definitions: **user/subscriber**; **traffic data**; **location data**; **communication**.
- Service providers must take technical/organisational security measures; member states must ensure confidentiality of communications and traffic data.
- Unsolicited communications / automated calls → require **prior consent** (express or implied); subscribers may object freely; subscriber directories need consent.

9.2 European Electronic Communications Code (Dir. (EU) 2018/1972, “Recast”)

Adopted around the same time as the GDPR; deals with **non-personal/general data** (economic value), complementing the ePrivacy Directive. Aims: fair competition between providers, an internal market in electronic communications, and connectivity across Europe.

9.3 Law Enforcement Directive (Dir. (EU) 2016/680)

Data protection in the **police/criminal** sector (prevention, investigation, detection, prosecution; execution of penalties). Adopted June 2016; **replaced Framework Decision 2008/977/JHA**. Facilitates cross-border exchange; introduces data protection by design/default for police, breach notification, mandatory DPOs; automated decisions must not rely on sensitive data nor discriminate. Repealed **Data Retention Directive 2006/24/EC** (*Digital Rights Ireland*).

10 European Data Strategy (2020)

Adopted **2020** to make the EU a leader in the data economy, within the **Digital Decade (2020–2030)**; legal basis: free economic initiative (CFR). The **GDPR paved the way** by ensuring the free flow of personal data under harmonised rules.

10.1 Three Aims

- **Free flow of personal data** — protection, privacy, portability, cross-border flow.
- **Free flow of non-personal data** — overcome data-localisation restrictions; availability/portability/interoperability.
- **Single market for data** — data sharing across sectors and infrastructure.

10.2 EU 2016 Data Protection Package (open-question)

Centred on the **GDPR (2016/679)**, complemented by the **Law Enforcement Directive (2016/680)**, the **ePrivacy Directive (2002/58)**, and **Regulation 2018/1725** (EU institutions). Together: a coherent, comprehensive data-protection system.

10.3 Legislative Package (open-question)

- **Regulation (EU) 2018/1807** — Free Flow of **Non-Personal Data**; lays down rules on **data localisation requirements** (any obligation, prohibition, condition, limit or requirement in MS law imposing the processing of data in a specific MS territory, or hindering such processing in another MS), which are in principle **prohibited**. Obliges member states to repeal any such provisions. Scope: processing provided as a service to users within the EU or carried out by a person established in the EU; limited application for mixed (personal + non-personal) datasets. Goals: encourage self-regulatory codes of conduct; contribute to a **competitive data economy**.
- **Data Governance Act (DGA, 2022)** — creates a framework for facilitating safe data sharing, setting conditions for **re-use** and **intermediation services**. Covers data held by **public bodies, private entities and citizens**. Defines ‘**Data**’ = any digital representation of acts, facts or information, including in the form of sound, visual or audiovisual recording.
- **Digital Services Act (DSA, 2022)** and **Digital Markets Act (DMA, 2022)** — joint aims: (1) creating a **safer digital space** where users’ fundamental rights are protected; (2) establishing a **level playing field** to foster innovation, growth and competitiveness.
- **AI Act** — **Regulation (EU) 2024/1689** — risk-based AI framework (Section 11). Aim: harmonised framework on AI for **respecting fundamental rights**; improving prediction, optimising operations and resource allocation, personalising service delivery; supports socially and environmentally beneficial outcomes and key competitive advantages.
- **Data Act (2023)** — grants **fair access to and use of data** (fair distribution of value by establishing clear rules for accessing/using data within the European data economy); **cross-sectoral** (applies to all sectors). Goals: increase **legal certainty** for companies and consumers; mitigate abuse of **contractual imbalances** impeding equitable data sharing; enable **public sector bodies** to access and use data held by the private sector for specific public-interest purposes; provide a framework enabling customers to **switch between data-processing service providers**.

DSA, DMA, AI Act do not strictly regulate personal data — they govern digitally-natured services/markets that use it, and integrate the GDPR.

11 The Artificial Intelligence Act (Regulation 2024/1689)

The first comprehensive, risk-based regulation of AI. Expands on the AI Act entry of the European Data Strategy package (Section 10). Source lecture: *Cosetta Masi, L2B Studio Legale, Padua, 15 January 2025*.

11.1 Rationale

Why an AI Act?

A harmonised EU framework is needed to (i) avoid **fragmentation** of the single market across member states, (ii) ensure a **level playing field** and fair competition, and (iii) build **trust and confidence** to encourage adoption.

Real-world friction: Meta halted EU roll-out of its AI model (July 2024); Apple delayed Apple Intelligence in the EU citing DMA/antitrust regulation (June 2024).

11.2 Subject Matter and Scope (Art. 1–2)

Subject matter (Art. 1) — harmonised rules for placing on market, putting into service and use of AI systems; prohibitions of certain practices; requirements for high-risk systems; transparency rules; rules for general-purpose AI (GPAI) models; market surveillance and governance; innovation support (focus on SMEs).

Applies to (Art. 2):

- **Providers** placing AI systems / GPAI models on the EU market — even if established in a third country
- **Deployers** located within the Union
- Providers/deployers in a third country where the **output is used in the Union** (extraterritoriality)
- Importers, distributors, product manufacturers, authorised representatives; affected persons in the Union

Does NOT apply to: FOSS-licensed systems; AI for sole scientific research/development; purely personal non-professional use (household exception); exclusive military/defence/national-security use; third-country authorities under international law-enforcement cooperation.

11.3 Key Definitions (Art. 3)

AI system

Machine-based system operating with varying autonomy, possibly adaptive after deployment; for explicit or implicit objectives, infers from input how to generate outputs (predictions, content, recommendations, decisions) influencing physical or virtual environments.

General-Purpose AI (GPAI) model

Model (often trained on large data via self-supervision at scale) with significant generality, competently performing a wide range of distinct tasks, integrable into downstream systems. Excludes R&D/prototyping models before market placement.

- **Provider** — develops a system/GPAI model and places it on market under own name, for payment **or free of charge**
- **Deployer** — uses a system under its authority (except personal non-professional use)
- **Operator** — umbrella: provider, product manufacturer, deployer, authorised representative, importer, distributor

11.4 Risk-Based Framework

Four risk tiers:

- **Minimal risk** — e.g. spam filters (no obligations)
- **Limited risk** — e.g. chatbots (transparency duties)
- **High risk** — e.g. recruitment, medical devices (strict requirements)
- **Unacceptable risk** — e.g. government social scoring (**prohibited**)

11.5 Prohibited Practices (Art. 5)

1. **Subliminal techniques** — manipulation via hidden triggers, causing harmful decisions
2. **Exploiting vulnerabilities** — of age, disability, social/economic situation
3. **Social scoring** — ranking by behaviour/characteristics; harmful where context-detached or disproportionate (cf. China Social Credit System)
4. **Predictive policing** — predicting offences *only* from profiling/personality traits (exception: supporting human assessment based on objective facts)
5. **Untargeted facial scraping** — building face databases from internet/CCTV
6. **Emotion inference** — in workplace or education institutions
7. **Biometric categorisation** — to deduce race, political opinions, trade-union membership, religion, sex life, sexual orientation
8. **Real-time remote biometric ID** in public spaces for law enforcement
 - Exceptions (strictly necessary): search for abduction/trafficking victims & missing persons; preventing substantial imminent threat / terrorist attack; locating a suspect for an Annex II offence punishable by ≥ 4 years

Recitals 15–16: **biometric identification** (matching against a reference DB) excludes mere **verification/authentication**; **biometric categorisation** excludes purely ancillary commercial features (e.g. marketplace try-on, social-media filters).

11.6 High-Risk Classification (Art. 6, Chapter III)

Two routes to high-risk

Route 1 (product safety): the AI is a safety component of, or is itself, a product covered by Annex I Union harmonisation legislation AND that product requires third-party conformity assessment.

Route 2 (use case): the AI falls under an Annex III use case.

Annex I sectors (selected): toys, lifts, explosive-atmosphere equipment, radio & pressure equipment, cableways, PPE, gas appliances, medical & IVD devices, civil aviation, vehicles (motor, agricultural, two/three-wheel), marine equipment, rail, unmanned aircraft.

Annex III high-risk use cases:

- **Biometrics** — remote identification, categorisation, emotion recognition
- **Critical infrastructure** — traffic, utilities (water/gas/heating/electricity), digital infrastructure
- **Education** — admissions, learning evaluation, level assessment, exam monitoring
- **Employment** — recruitment, promotion/termination, task allocation, performance monitoring
- **Essential services** — benefit eligibility, credit scoring, life/health insurance pricing, emergency dispatch

- **Law enforcement** — victim/offender risk, lie detectors, evidence evaluation, criminal profiling
- **Migration & borders** — risk assessment, application processing, identity verification
- **Justice & democracy** — assisting judicial interpretation, influencing elections/voting

Derogation (Art. 6): an Annex III system is *not* high-risk if it poses no significant harm and only performs a narrow procedural task, improves a prior human activity, detects deviations without replacing human assessment, or performs a preparatory task. **Override:** always high-risk if it performs **profiling** of natural persons.

11.7 Requirements for High-Risk Systems (Art. 9–15)

Provider duties *before* market placement; verified via **conformity assessment by a notified body**.

Article	Requirement
Art. 9	Risk management system — identify → assess → mitigate (incl. testing) → monitor → report
Art. 10	Data governance — quality, security, governance; detect/prevent/mitigate biases
Art. 11	Technical documentation — design, code, risk results (contents in Annex IV)
Art. 12	Record keeping — automatic logging (use periods, reference DB, matches, verifiers)
Art. 13	Transparency — inform users of capabilities/limits/biases; provide instructions; explainability
Art. 14	Human oversight — human-in-the-loop interface; ability to interpret output and interrupt
Art. 15	Accuracy, robustness, cybersecurity — benchmarks, documented accuracy, feedback-loop control

Provider obligations summarised as **transparency, fairness** (no discrimination) and **accountability** for system performance and impact.

11.8 Challenges and Fundamental Rights

Challenges/limitations: data availability (niche sectors); legal complexity and interpretation; effective enforcement and oversight.

Fundamental rights protected: human dignity (no discriminatory systems), privacy (data protection, autonomy), freedom of expression (no censorship).

11.9 Entry into Force and Timeline

- In force on the 20th day after OJEU publication; **general application: 2 August 2026**
- **2 February 2025** — Chapters I (general) and II (prohibited practices)
- **2 August 2025** — notifying authorities, standards/registration, governance, penalties, Art. 78 (except Art. 101)
- **2 August 2027** — Art. 6(1) high-risk (product-safety route) obligations

12 Key Cases & Cross-Cutting Concepts

12.1 Leading Cases

12.1.1 Van Gend en Loos (26/62, 1963)

Why: Van Gend en Loos, a Dutch transport firm, imported a chemical from West Germany and was charged a customs duty it believed breached the Treaty of Rome (which aimed to abolish such duties).

Forum: it sued before the Dutch first-instance customs court, which referred the question to the **ECJ** via preliminary ruling.

Ruling: the EU created a **new legal order** whose law is an **integral part** of member states' systems and has **direct effect** — individuals may invoke Treaty provisions before national courts.

Consequences: citizens (not only states) can enforce EU law nationally; foundation of the doctrine of direct effect.

12.1.2 Costa v. ENEL (6/64, 1964)

Why: Italy nationalised electricity, creating the state company ENEL; Mr Costa, an **Edison-volta** shareholder, refused to pay his (small) electricity bill, claiming the nationalisation breached the Treaty of Rome and the Italian Constitution.

Forum: two parallel suits before a **Milan justice of the peace** — one referred to the **Italian Constitutional Court** (which held the constitution allowed limiting sovereignty but conflicting rules could prevail), one to the **ECJ**.

Ruling: the ECJ held the Community is a **New Legal Order** for which states **permanently limited their sovereign rights**; Costa had no standing to block the nationalisation but could raise EU-law incompatibility before his national court.

Consequences: established the **primacy** of EU law over conflicting national law.

12.1.3 Schrems v. Facebook (2015)

Why: Austrian activist Max Schrems complained that Facebook (EU-subject, US-based) transferred EU users' personal data to the US, where (post-Snowden) mass surveillance gave no **adequate** protection — breaching the fundamental right to data protection.

Forum: complaint to the Irish data-protection authority, then referred to the **ECJ**.

Ruling: the ECJ declared the EU-US **Safe Harbor** agreement **void** for failing to ensure protection equivalent to the EU's.

Consequences: transatlantic transfers had to be re-grounded; the EU and US concluded a new agreement with **improved standards** (and US protection levels were raised).

12.1.4 Google Spain — Costeja Gonzalez (C-131/12, 2014)

Why: Mario Costeja Gonzalez found that Google searches on his name still linked to old newspaper articles about a resolved debt, damaging his reputation without serving any present public interest.

Forum: complaint to the Spanish data-protection authority against Google Spain; referred to the **ECJ**. **Ruling (2014):** the ECJ found in his favour, holding search engines are controllers and establishing the **Right to be Forgotten** — individuals may request **de-listing** of outdated/irrelevant personal information lacking public interest.

Consequences: de-listing right now exercisable EU-wide; requires a **proportionality** balance between privacy and the public's right to information.

12.1.5 Digital Rights Ireland (C-293/12 + C-594/12)

Why: the **Data Retention Directive (2006/24/EC)** obliged providers to retain traffic/location data en masse for law enforcement — challenged as a disproportionate interference with privacy and data protection.

Forum: references from the Irish High Court and the Austrian Constitutional Court to the **ECJ**.

Ruling: the directive was **declared invalid (repealed)** for failing the proportionality and necessity tests (blanket, untargeted retention).

Consequences: mass data-retention regimes lost their EU legal basis; reaffirmed proportionality as the limit on surveillance measures.

12.2 Proportionality Scrutiny (open-question)

A structured judicial **test** to balance competing rights; **sequential** — failing any step makes the measure unlawful and ends the scrutiny:

1. **Legitimate goal?** — does the measure pursue a legitimate general-interest aim?
2. **Rational connection?** — is it concretely suited to that goal (some courts omit this step)?
3. **Necessary?** — is it the **least restrictive means**?
4. **Proportionate (stricto sensu)?** — do benefits outweigh the harm to the affected rights/interests?

12.3 Social Credit Systems (open-question)

Three legal problems

(1) **Privacy & data protection** — mass collection, aggregation and continuous monitoring of personal data, often without genuine consent or transparency. (2) **Discrimination / equality** — opaque, possibly biased automated scoring produces unjustified differential treatment and social exclusion. (3) **Due process & rule of law** — sanctions without clear legal basis, procedural safeguards or remedies; plus **chilling effects** on freedom of expression/association. Under the AI Act, government social scoring is an **unacceptable-risk, prohibited** practice (Art. 5).

12.4 Barbra Streisand Effect (open-question)

The paradox

Trying to suppress information through legal action can **increase** its dissemination. In 2003 Streisand sued to remove aerial photos of her house; before the suit the images were barely seen, after it they spread widely. Takeaways: legal protection of privacy can **backfire** (sometimes not acting protects privacy better); the **legal vindication** of privacy differs from — and can oppose — its **social enjoyment**.

12.5 Synthetic Data (open-question)

Definition & relevance

Artificial data generated from **original data** and a **model** that is trained to reproduce the characteristics and structure of the original data; the generation process is called **synthesis**. Synthetic data and original data should deliver very similar results when undergoing the same statistical analysis. No EU legislative definition yet. Relevant to privacy: reduced re-identification risk, enables sharing/collaboration, overcomes data scarcity. As it does not relate to identifiable persons, it generally falls **outside the GDPR**. Distinct from **anonymised** data (which irreversibly lose detail and are therefore less useful for training).

12.6 Big Data

Definition

Great **volume, velocity and variety** of (personal and non-personal) **data**, combined with the **technological ability** to collect, process and extract **new and predictive knowledge** from them. Big data processing often involves personal data, triggering GDPR obligations, while simultaneously involving non-personal data governed by Reg. 2018/1807. The ability to derive predictive knowledge creates tension with purpose limitation and data minimisation principles.

13 Privacy Policy Components

A robust privacy policy addresses:

1. **Data Collection** — types of personal data collected
2. **Collection Methods** — forms, cookies, indirect methods
3. **Data Utilization** — purposes (operational, analytical, marketing)
4. **Data Storage** — methods, retention periods, security
5. **Marketing Practices** — promotional use and opt-out options
6. **Data Protection Rights** — access, rectification, deletion
7. **Authority Contacts** — controller and supervisory authority information
8. **Cookie Usage** — types, purposes, management instructions

A Quick Reference Tables

A.1 Data Subject Rights under GDPR

Right	Description
Access	Obtain confirmation and copy of personal data
Rectification	Correct inaccurate or incomplete data
Erasure	Request deletion (“right to be forgotten”)
Restriction	Limit processing in certain circumstances
Data portability	Receive data in portable format
Object	Object to processing based on legitimate interests
Automated decisions	Not be subject to solely automated decisions
Complaint	Lodge complaint with supervisory authority

A.2 Controller vs Processor Obligations

Controller	Processor
Determine purposes and means	Act on controller’s instructions
Primary accountability	Implement TOMs
Record processing activities	Record processing activities
Cooperate with subjects/authorities	Cooperate with authorities
Designate DPO (if required)	Designate DPO (if required)
Appoint processors contractually	Appoint sub-processors (with authorization)

A.3 GDPR Principles Summary

Principle	Key Requirement
Lawfulness	Legal basis required (consent, contract, etc.)
Fairness	Processing must be fair to data subjects
Transparency	Clear information about processing
Purpose limitation	Specific, explicit, legitimate purposes
Data minimization	Adequate, relevant, not excessive
Accuracy	Correct, up-to-date data
Storage limitation	Keep only as long as necessary
Integrity & Confidentiality	Appropriate security measures
Accountability	Demonstrate compliance

A.4 Sources Hierarchy (EU)

Level	Content
Primary law	Treaties (TEU, TFEU), Charter, general principles
International agreements	Concluded by the EU (Art. 216–218 TFEU)
Secondary law	Regulations, directives, decisions, recommendations
Supplementary law	CJEU case law, general principles

B EU Institutional Infrastructure

The institutions are established by **Art. 13 TEU**. Below: composition, function and seat of each body, plus the dedicated data-protection bodies.

B.1 Core Institutions (Art. 13 TEU)

Institution	Composition	Function
European Parliament	720 members, directly elected (since 1979) for 5 years; proportional to each state's population; political groups by affinity, not nationality. Seats: Strasbourg (plenary), Brussels (committees), Luxembourg (secretariat).	Legislative (co-legislator with the Council); budgetary (monitors, does not manage spending); supervisory (democratic scrutiny, inquiries, petitions); elective (elects the Commission President, approves commissioners).
European Council	Heads of state/government (27) + a president (2.5-year term) + Commission President.	Sets the EU's overall political direction and priorities; does not legislate ; guides legislative policy.
Council of the EU (Council of Ministers)	One minister per member state, varying by topic (e.g. interior ministers); each can commit its state.	First legislative chamber ; co-legislates with Parliament; amends, approves or vetoes Commission proposals; sole competent body for CFSP data rules (Art. 39 TEU).
European Commission	27 commissioners (one per state), independent; President proposed by the European Council, elected by Parliament; organised into Directorates-General.	Sole initiator of legislation; guardian of the treaties (enforces EU law); executive & budgetary powers (manages the EU budget); represents the EU externally, signs international agreements.
Court of Justice of the EU (CJEU)	Court of Justice (1 judge/state + 11 advocates general) + General Court (2 judges/state); judges appointed, 6-year renewable, independent.	Ensures uniform interpretation & application of EU law; preliminary rulings, annulments, infringement & failure-to-act actions, damages.
European Central Bank (ECB)	EU's central bank (euro-area monetary authority).	Manages the euro and EU monetary policy.
Court of Auditors	One member per state.	Oversees EU finances (audit).

B.2 Council of the EU vs European Council (don't confuse)

- **European Council** — *heads of state/government*; political **direction only**, no legislative power.
- **Council of the EU** — *ministers*; **legislates** jointly with the Parliament.
- (Distinct again from the **Council of Europe** — a separate, non-EU organisation running the ECHR.)

B.3 CJEU — Two Courts

Court of Justice	General Court
Preliminary rulings from national courts, annulment actions, appeals. 1 judge per state + 11 advocates general.	Annulment actions by individuals/companies/governments (competition, State aid, trade, agriculture, trademarks). 2 judges per state.

Functions: jurisdictional (litigation between parties), interpretative (preliminary rulings, Art. 267), advisory (opinions). **Proceedings:** annulment/direct appeals (Art. 263, 2 months + 10 days), failure to act (Art. 265), damages (Art. 340(2)), infringement actions against states.

B.4 Data-Protection Bodies

Body	Role
EDPS (Eur. Data Protection Supervisor)	Independent authority supervising processing by EU institutions only ; handles their breach reports.
EDPB (Eur. Data Protection Board)	Independent body gathering the national supervisory authorities ; ensures consistent application of data-protection rules; successor to the Art. 29 Working Party.
National Supervisory Authorities	One per member state; independent; handle complaints, enforce the GDPR, cooperate via the EDPB (GDPR Art. 51; basis Art. 8 CFR).
Commission agencies	Decentralised EU bodies with specific tasks.
Fundamental Rights Agency	Seated in Vienna ; focuses on core rights and freedoms.